

AUDIT PLAN ASSIGNMENT

For this assignment, I selected a small business within my neighborhood, a nail salon that I regularly visit, as the subject of my operational audit. In respect of privacy and at the request of the manager, the business name will not be disclosed. The decision to focus on this salon stemmed from my familiarity with its operations and my interest in assessing how a small, service-oriented business manages its cybersecurity and operational practices. This setting provided an excellent opportunity to evaluate real-world controls, data management practices, and security awareness in a small business environment.

Purpose

The purpose of this audit plan is to evaluate the cybersecurity posture, operational compliance, and data protection measures of the nail salon. The assessment aims to ensure that customer data, including payment information and client records, are securely managed, that business continuity is maintained through effective controls, and that the salon complies with general regulatory and industry best practices.

Outcome

The expected outcome of the audit is to identify existing security gaps, operational risks, and areas for improvement while documenting key findings and offering actionable recommendations. The goal is to help the salon align its cybersecurity and operational practices with small-business security frameworks and best-practice standards to strengthen its resilience and data protection capabilities.

Scope

The scope of the audit covered both digital and physical components of the salon's operations, including:

- IT systems (Point-of-Sale, booking applications, and Wi-Fi configuration)
- Staff devices and access controls
- Data backup procedures and privacy practices
- Physical and environmental safety controls (surge protection, CCTV, fire safety)
- Vendor and payment processing security compliance
- Employee awareness of cybersecurity practices and daily operational procedures

Audit Procedure

Arrival:

Upon arrival at noon, I met with the salon owner and manager to explain the purpose of the audit, confirm access to relevant systems (Wi-Fi, POS terminals, and employee devices), and verify written and verbal consent for non-intrusive system checks.

Introduction:

I outlined the audit's objectives, scope, and methodology, emphasizing confidentiality of results and the importance of transparency during the process. We also agreed to a timeline for the audit and an end-of-day debrief to review key observations.

Audit Meeting:

After the audit was completed, I presented the findings to the owner, categorized identified risks as low, medium, or high, and discussed actionable recommendations for each issue. We agreed on corrective action steps, accountability assignments, and a realistic timeline for implementation.

Audit Hot Wash: Once the attached Audit Plan document was completed, I informed the nail salon manager that the audit activities had concluded and proceeded to conduct a post-audit meeting. The purpose of this meeting was to review and discuss the initial findings, highlight areas of concern, and ensure the manager clearly understood each observation. Together, we collaborated to develop and agree upon an action plan, outlining specific corrective measures, any additional information required, and potential recommendations for improving the salon's cybersecurity and operational practices. This debrief served as an important opportunity to validate results, align priorities, and reinforce the salon's commitment to strengthening its overall security posture.

Audit Commenced (time/date): 12:00 PM, November 7, 2025

Audit Complete (time/date): 2:30 PM, November 7, 2025

Auditor: Tiwa Shadare.

Item #	Description	Expected Findings/pass criteria
1	Check password strength	All accounts (POS, Wi-Fi, devices, social media) use strong passwords: ≥12 characters, mix of cases, numbers, symbols.
2	Check for missing updates	All systems and apps (POS, browsers, OS, antivirus) updated within last 30 days.
3	Check for back ups	Automated or manual backups verified (daily/weekly) to cloud or external drive.
4	Review antivirus/antimalware protection	Licensed software installed, updated, and performing scheduled scans.
5	Check Wi-Fi security	WPA3/WPA2 encryption; hidden SSID optional; guest network separated from POS/office network.
6	Inspect firewall settings	Hardware/software firewall enabled and logging.

7	Review user access control	Only authorized staff have system login access; terminated employees' access revoked.
8	Review POS system security	Transactions encrypted; customer data not stored locally; PCI-DSS compliant.
9	Review physical security	Security cameras functional; cash register and storage areas locked after hours.
10	Inspect workstation security	Screens auto-lock after 5 minutes of inactivity; minimal use of USB drives.
11	Evaluate data privacy practices	Client records securely stored; consent forms compliant with privacy policy.
12	Check incident response preparedness	Staff know whom to contact in event of cyber incident; documented plan exists.
13	Verify staff training	Employees trained on phishing, password hygiene, and customer data handling.
14	Review third-party services	Verify that third-party vendors (POS provider, booking apps) follow secure practices.
15	Check business continuity plan	Recovery steps documented; essential contacts and backup sources listed.
16	Test website security (if applicable)	HTTPS enabled; SSL certificate valid.
17	Inspect IoT devices (e.g., cameras, smart locks)	Default passwords changed; firmware updated; devices isolated on guest or IoT network.
18	Review client booking software	Platform uses encrypted connections (HTTPS).
19	Environmental and safety audit	Fire extinguisher and first aid kits accessible; emergency exits clear.
20	Data disposal	Sensitive data shredded/wiped.
21	Device inventory	Inventory maintained and labeled.
22	Internet speed and reliability	Internet connection stable and secure.
23	VPN usage for remote access	Staff use VPN for offsite access.
24	Social media account security	Business pages secured with MFA.
25	Printer and shared devices	No sensitive data left on printers.
26	Surveillance data storage	Security footage stored securely and deleted after retention period.
27	Mobile device management	Salon phones/tablets secured by PIN or biometrics.

28	Electrical and surge protection	All major equipment on surge protectors.
29	Check ports using ShieldsUP	Ports are in stealth or closed
30	License and compliance checks	All licenses and insurance valid.